



OT SOC

FOUNDATIONAL GUIDE



TABLE OF CONTENTS

EXECUTIVE SUMMARY	3
1. OT SOC FOUNDATIONS — WHY THIS IS DIFFERENT	4
1.1 THE OT/IT DIVERGENCE — A FIELD-LEVEL REALITY CHECK	4
1.2 THE FIVE CRITICAL OT THREAT CATEGORIES	4
<i>Category 1: IT-Sourced Lateral Movement.....</i>	<i>5</i>
<i>Category 2: Engineering Workstation Compromise.....</i>	<i>5</i>
<i>Category 3: Supply Chain and Vendor Access Exploitation.....</i>	<i>5</i>
<i>Category 4: Insider Threat and Sabotage.....</i>	<i>5</i>
<i>Category 5: Nation-State Pre-Positioning and Destructive Attacks.....</i>	<i>5</i>
2. OT SOC MODELS — SELECTING THE RIGHT ARCHITECTURE	7
2.1 THE FIVE SOC MODEL ARCHETYPES	7
<i>Model A: Dedicated OT SOC (Greenfield).....</i>	<i>7</i>
<i>Model B: Fused IT/OT SOC with Dedicated OT Tier.....</i>	<i>7</i>
<i>Model C: OT Remote Monitoring Centre (MSSP-Led).....</i>	<i>7</i>
<i>Model D: Asset Owner Collaborative SOC (Sector ISAC-Aligned).....</i>	<i>8</i>
<i>Model E: Virtual/Distributed OT SOC.....</i>	<i>8</i>
2.2 SOC TIERING MODEL FOR OT.....	8
2.3 STAFFING MODEL AND SHIFT DESIGN.....	9
3. OT SOC ARCHITECTURE — TECHNICAL BLUEPRINT	10
3.1 REFERENCE ARCHITECTURE PRINCIPLES.....	10
3.2 NETWORK VISIBILITY LAYERS AND COLLECTION ARCHITECTURE.....	10
3.3 TECHNOLOGY STACK — RECOMMENDED COMPONENTS	11
<i>3.3.1 OT-Native Network Detection and Response (NDR).....</i>	<i>11</i>
<i>3.3.2 SIEM — OT-Contextualised Correlation.....</i>	<i>11</i>
<i>3.3.3 OT Asset Inventory and Vulnerability Management.....</i>	<i>11</i>
<i>3.3.4 Remote Access Security — A Non-Negotiable Control.....</i>	<i>11</i>
<i>3.3.5 OT Threat Intelligence Platform.....</i>	<i>12</i>
4. OPERATIONAL GOALS AND MISSION FRAMEWORK	13
4.1 OT SOC MISSION STATEMENT	13
4.2 STRATEGIC OPERATIONAL GOALS — HIERARCHY	13
4.3 USE CASE LIBRARY — OT SOC DETECTION COVERAGE	14
5. OT SOC KPIS, METRICS AND PERFORMANCE FRAMEWORK	16
5.1 THE OT SOC MEASUREMENT PHILOSOPHY	16
5.2 TIER-1: EXECUTIVE AND BOARD-LEVEL KPIS (CISO DASHBOARD)	16
5.3 TIER-2: OPERATIONAL KPIS (SOC LEAD DASHBOARD).....	17
5.4 TIER-3: TECHNICAL AND ANALYST-LEVEL METRICS.....	18
6. OT INCIDENT RESPONSE — PLAYBOOK FRAMEWORK.....	19
6.1 THE OT IR DOCTRINE — SAFETY BEFORE SPEED	19
6.2 OT INCIDENT SEVERITY CLASSIFICATION	19
6.3 MASTER PLAYBOOK — RANSOMWARE IN OT ENVIRONMENT	20
<i>Phase 1: Detection and Initial Triage (T+0 to T+15 minutes).....</i>	<i>20</i>
<i>Phase 2: Safety Assessment (T+15 to T+30 minutes).....</i>	<i>21</i>
<i>Phase 3: Containment (T+30 to T+90 minutes — safety-cleared only).....</i>	<i>21</i>
<i>Phase 4: Eradication and Recovery (T+90 minutes onwards).....</i>	<i>21</i>
7. SECURITY CONTROLS FRAMEWORK — OT SOC APPLICATION.....	22
7.1 CONTROLS ARCHITECTURE — THE DEFENCE-IN-DEPTH MODEL FOR OT	22
7.2 PREVENTIVE CONTROLS — THE SOC'S PREREQUISITES	22
7.3 DETECTIVE CONTROLS — THE SOC'S PRIMARY TOOLKIT	23
7.4 RESPONSIVE CONTROLS — SOC EXECUTION TOOLKIT.....	24
8. RESIDUAL RISK FRAMEWORK — HONEST ACCOUNTING	25

8.1 WHY RESIDUAL RISK MUST BE EXPLICITLY DOCUMENTED	25
8.2 INHERENT RESIDUAL RISKS IN OT SOC OPERATIONS	25
8.3 QUANTIFIED RISK ACCEPTANCE FRAMEWORK	26
<i>Consequence Categories for OT Risk Quantification</i>	27
9. GOVERNANCE, COMPLIANCE AND REGULATORY ALIGNMENT	28
9.1 OT SOC GOVERNANCE CHARTER — MINIMUM REQUIREMENTS.....	28
9.2 REGULATORY FRAMEWORK CROSS-REFERENCE	28
9.3 OT SOC MATURITY MODEL	29
10. CISO AND SECURITY LEADER ACTION GUIDE	31
10.1 THE 90-DAY OT SOC LAUNCH PROGRAMME.....	31
<i>Days 1–30: Foundation and Assessment</i>	31
<i>Days 31–60: Technology and Process</i>	31
<i>Days 61–90: Operationalisation and Governance</i>	31
10.2 THE FIVE QUESTIONS EVERY CISO MUST BE ABLE TO ANSWER	32
11. APPENDIX — REFERENCE MATERIALS AND TEMPLATES	33
11.1 OT SOC TECHNOLOGY SELECTION CRITERIA.....	33
11.2 OT SOC PROGRAMME BUDGET PLANNING REFERENCE	33
11.3 RECOMMENDED READING AND REFERENCE STANDARDS	34
11.4 GLOSSARY OF OT SOC TERMS.....	35

EXECUTIVE SUMMARY

Operational Technology environments are the nervous system of modern civilisation. They govern the flow of electricity across national grids, maintain the precise chemistry of water treatment, keep oil and gas pipelines operating within safety tolerances, and orchestrate the synchronised machinery of complex manufacturing lines. Unlike enterprise IT, a breach in an OT environment does not merely expose data — it can cause physical destruction, environmental catastrophe, loss of human life, and cascading failures across interdependent critical infrastructure.

Despite this reality, the vast majority of industrial organisations continue to operate without a dedicated, purpose-built OT Security Operations Centre. Many attempt to extend an existing IT SOC into the OT domain — an approach that consistently fails because the tools, telemetry sources, threat models, response playbooks, and human expertise required are fundamentally different. The result is a false sense of security: monitoring coverage that looks credible on paper but is blind to the threats that matter most.

This guide provides a complete blueprint for establishing, maturing, and sustaining a genuine OT SOC. It covers the full lifecycle: from the foundational decisions that determine what kind of SOC an organisation needs, through the architectural choices that make it operationally viable, to the metrics that prove its effectiveness and the residual risk framework that enables honest conversations with boards and regulators.

Core Premise

An OT SOC is not a technology investment — it is an operational capability. Technology enables it; people, processes, and institutional knowledge sustain it. Organisations that invest in detection tooling without investing equally in trained analysts, validated playbooks, and tested response procedures will achieve visibility without the ability to act — which, in an OT environment, can be more dangerous than no visibility at all.

The six principles that govern every recommendation in this guide are: (1) Safety is the non-negotiable constraint — no security action will ever take precedence over physical process safety; (2) Availability is the primary security objective in OT, not confidentiality; (3) Passive monitoring is the default — active scanning and intrusive tooling require explicit engineering sign-off; (4) Response playbooks must be tested against the actual process, not theoretical scenarios; (5) The OT SOC operates as a trusted partner with Operations and Engineering, not as an adversarial audit function; and (6) Residual risk must be quantified, documented, and owned — not buried in assumption logs.

1. OT SOC FOUNDATIONS — WHY THIS IS DIFFERENT

1.1 The OT/IT Divergence — A Field-Level Reality Check

Security professionals who come from an IT background often underestimate the depth of the operational difference. The table below captures the fundamental divergences that must inform every design decision, staffing choice, and tooling selection in an OT SOC.

Dimension	Enterprise IT SOC	OT SOC
Primary asset	Data and services	Physical processes and safety systems
Security priority order	Confidentiality → Integrity → Availability	Safety → Availability → Integrity → Confidentiality
Asset lifecycle	3–5 years; patched regularly	15–30 years; rarely patched; legacy by design
Downtime tolerance	Minutes to hours (RTO/RPO driven)	Often zero — unplanned outage equals production loss or safety event
Protocol landscape	TCP/IP standard stack	DNP3, Modbus, PROFINET, EtherNet/IP, IEC 61850, OPC-DA/UA, ICCP, BACnet, and dozens more
Active scanning	Standard practice	Can crash PLCs, disrupt comms — requires explicit engineering approval for every target
Incident response	Isolate, contain, eradicate, recover	Safety assessment first; isolation may worsen process state; physical consequences of actions
Threat actor profile	Broad; financially motivated predominant	Nation-state APTs, hacktivists, ransomware operators with OT-specific destructive payloads (INDUSTROYER, TRITON, PIPEDREAM)
Vendor access	Standard remote admin channels	Proprietary vendor portals, modem lines, jump hosts specific to each vendor DCS/SCADA stack
Change management	Continuous or sprint-based	Highly formal; change windows dictated by production cycles, turnarounds, planned outages
Log availability	Rich syslog, event logs, API telemetry	Often minimal; many PLCs and RTUs produce no logs at all; telemetry comes from network observation

1.2 The Five Critical OT Threat Categories

Two decades of incident response in OT environments reveals that threats cluster into five operationally distinct categories. The OT SOC must be designed and tuned to detect and respond to all five, not just the most common.

Category 1: IT-Sourced Lateral Movement

The most frequent OT security incident is IT malware — most commonly ransomware — propagating through an IT/OT boundary that is insufficiently enforced. Attackers compromise IT networks first, then pivot to OT through shared credentials, inadequately segmented historian servers, or direct network reachability through misconfigured firewalls. Notable examples include the 2021 Oldsmar Water Treatment attack, the Colonial Pipeline incident, and the 2022 German wind turbine operator breach.

Category 2: Engineering Workstation Compromise

Engineering workstations (EWS) are the highest-value targets in any OT environment. They hold project files for PLCs, HMIs, and DCS systems; they frequently have direct connections to field devices for programming; and they are often poorly hardened because operational engineers prioritise functionality over security. A compromised EWS gives an attacker the ability to modify logic on field controllers — the exact capability used in the Triton/TRISIS attack against a Safety Instrumented System in 2017.

Category 3: Supply Chain and Vendor Access Exploitation

OT environments depend on a complex ecosystem of OEM vendors, system integrators, and maintenance contractors. These parties frequently require remote access, often through dedicated remote access infrastructure or even legacy modem connections. Their laptops and tools are rarely subject to the same security standards as the operator's own estate. The 2020 SolarWinds compromise, while primarily an IT incident, demonstrated the industrial scale of supply chain risk. OT-specific examples include compromised engineering software update channels.

Category 4: Insider Threat and Sabotage

Given the direct physical consequence of OT actions, insider threats carry outsized risk. Disgruntled employees, contractors with residual access, or employees coerced by external actors can cause significant harm with a small number of actions — changing setpoints, disabling alarms, or modifying logic. The 2000 Maroochy Water Services incident, where a disgruntled contractor caused 800,000 litres of sewage to spill, remains the archetype.

Category 5: Nation-State Pre-Positioning and Destructive Attacks

Advanced persistent threat actors — including those attributed to nation-states — have demonstrated the capability to pre-position within OT environments for extended periods, await operational timing, and then execute destructive payloads. CRASHOVERRIDE/INDUSTROYER targeted Ukrainian power grid infrastructure in 2016. TRITON targeted a Saudi petrochemical facility's safety systems in 2017. PIPEDREAM (INCONTROLLER), disclosed in 2022, represents a modular OT attack framework targeting multiple industrial protocols simultaneously. These threats require proactive threat hunting, not reactive alerting.

Field Observation

In practice, the majority of OT security incidents that require SOC response begin with human error or supply chain compromise, not sophisticated cyberattack. A well-designed OT SOC must therefore be equally capable of detecting configuration drift, accidental connectivity changes, and unauthorised removable media as it is of hunting for nation-state implants. The mundane and the sophisticated both matter.

2. OT SOC MODELS — SELECTING THE RIGHT ARCHITECTURE

2.1 The Five SOC Model Archetypes

There is no single correct OT SOC model. The right choice depends on the organisation's size, sector, geographic footprint, regulatory obligations, existing IT security capability, and critically — the operational maturity of the OT environment itself. The following five archetypes cover the realistic spectrum.

Model A: Dedicated OT SOC (Greenfield)

A purpose-built facility with physically separate SIEM, analyst workstations, and network access dedicated exclusively to OT monitoring. Staff are OT-native or cross-trained. Technology stack is selected independently of the IT SOC. This model provides the highest detection fidelity but carries the highest cost and requires a large, mature OT environment to justify the investment.

Best suited for: Tier 1 critical infrastructure operators — national grid operators, large refinery complexes, major water utilities, Tier 1 automotive manufacturers.

Minimum viable scale: Organisations operating 500+ OT assets across multiple sites, with regulatory obligations (NERC CIP High Impact, NIS2 Essential Entity, IEC 62443 SL2+).

Model B: Fused IT/OT SOC with Dedicated OT Tier

The IT SOC infrastructure (SIEM, SOAR, ticketing) is shared, but a dedicated OT monitoring tier sits within it: separate SIEM rules, separate analyst queues, OT-specific playbooks, and at least one OT-trained analyst on each shift. This is the most commonly deployed model in mid-to-large industrial organisations and, when implemented properly, delivers strong capability at manageable cost.

Critical success factor: The OT team must have authority to block proposed changes from IT SOC staff that would affect OT systems. A governance charter defining decision rights is non-negotiable.

Model C: OT Remote Monitoring Centre (MSSP-Led)

The organisation retains a lean internal OT security team (2–4 FTEs) for relationship management, playbook governance, and tier-3 escalation. Day-to-day monitoring is outsourced to a specialist OT MSSP. This model is appropriate for mid-market operators who lack the budget or talent pipeline for an internal SOC but need to demonstrate regulatory compliance.

Key risk: Institutional knowledge resides with the MSSP, not the operator. If the MSSP relationship ends, the operator is left with minimal internal capability. Contractually mandate

knowledge transfer obligations and require the MSSP to co-author all playbooks with internal staff.

Model D: Asset Owner Collaborative SOC (Sector ISAC-Aligned)

Common in sectors with established ISACs (E-ISAC for energy, WaterISAC for water, etc.), this model involves multiple asset owners contributing telemetry to a sector-level monitoring capability. Individual organisations maintain their own L1 detection capability, with cross-sector threat intelligence and L2/L3 shared through the collaborative. This model excels at sector-wide threat detection but requires careful data governance to manage competitive sensitivities.

Model E: Virtual/Distributed OT SOC

For organisations with highly distributed OT assets — a pipeline operator with 200 unmanned compressor stations, a national water utility with 400 pumping stations — a centralised physical SOC cannot practically provide adequate coverage. The distributed model places lightweight detection sensors at each site with aggregation to a central analysis platform. Analysts may work from multiple geographic locations. This model requires robust remote access security and a strong asset inventory discipline.

2.2 SOC Tiering Model for OT

Regardless of the macro-model chosen, every OT SOC should implement a tiered analyst structure. The following defines the recommended tier structure adapted specifically for OT operational realities.

Tier	Title	Core Responsibilities	OT-Specific Requirement
T1	Alert Analyst	Alert triage, initial classification, ticket creation, playbook execution for known scenarios, escalation	Must understand OT asset types, basic ICS protocol behaviour, normal vs. anomalous process communication patterns
T2	SOC Investigator	In-depth alert investigation, network forensics, log correlation, containment recommendations, playbook development	Must be able to read OT protocol captures (Modbus, DNP3, EIP), understand P&ID diagrams, liaise directly with Control Room
T3	Senior Threat Analyst / Hunter	Threat hunting, APT campaign tracking, SIEM tuning, red team co-ordination, escalation authority for safety-impacting incidents	Deep OT protocol expertise, ICS malware reverse engineering capability, direct authority to invoke safety response procedures
T4	OT SOC Lead / CISO Interface	SOC governance, KPI oversight, regulatory reporting, vendor management, board-level	Qualified in both security management (CISM/CISSP) AND OT

Tier	Title	Core Responsibilities	OT-Specific Requirement
		communication, risk acceptance authority	operational context (minimum ISA/IEC 62443 Cybersecurity Expert level)

2.3 Staffing Model and Shift Design

OT SOC staffing is typically under-provisioned because organisations model headcount against IT SOC benchmarks. OT analysis takes longer: alert investigation requires understanding process context, consulting with operations engineers, and careful triage to avoid false-positive responses that could disrupt production. The following staffing model represents the verified minimum for continuous 24/7 coverage.

Coverage Model	Shift Pattern	FTE Required	Notes
24/7 Follow-the-sun (single large org)	4 x 10hr or 3 x 8hr rotating	14–18 FTE	Includes lead, T1-T3 coverage, threat hunter, and 20% flex for leave/training
Business hours + on-call (mid-market)	8hr business days + on-call rota	6–8 FTE	On-call response SLA must be defined and tested; risk accepted for off-hours gaps
MSSP hybrid (monitoring outsourced)	MSSP 24/7 + internal 8hr oversight	3–4 FTE internal	Internal team must be empowered to override MSSP recommendations
Distributed virtual SOC	Regional analyst pools across time zones	8–12 FTE	Requires strong collaboration tooling and documented handoff procedures

Staffing Reality Check

The single biggest obstacle to OT SOC success is not budget — it is talent. OT SOC analysts who combine genuine ICS engineering knowledge with cybersecurity skill are exceptionally rare. Organisations must plan for a 12–24 month development pipeline: hire for OT knowledge, train for security, or hire for security and provide structured OT cross-training. Neither shortcut (IT-only analysts, or OT engineers with no security training) produces effective OT SOC practitioners.

3. OT SOC ARCHITECTURE — TECHNICAL BLUEPRINT

3.1 Reference Architecture Principles

The OT SOC technology stack must be designed around three inviolable principles: passive collection as the default, OT protocol native parsing, and physical network segmentation between the SOC monitoring infrastructure and the OT operational network. The SOC monitors the OT environment; it must never become part of it.

Architecture Principle — The Monitoring Paradox

Every piece of monitoring infrastructure you deploy in an OT network is itself an attack surface. A compromised sensor or monitoring agent sitting on the OT network is a threat actor's bridge into your most sensitive environment. Minimise the SOC footprint inside the OT network; aggregate and analyse outside it.

3.2 Network Visibility Layers and Collection Architecture

Comprehensive OT SOC visibility requires collecting telemetry from five distinct layers. Many organisations focus exclusively on the network layer and miss the process and application layers that are most relevant to OT-specific threats.

Layer	Source Types	Collection Method	Key OT Telemetry
Network (L2/L3)	Managed switches, routers, firewalls, IDS sensors	Passive SPAN/TAP — never inline active devices without engineering approval	Flow data, Modbus reads/writes, DNP3 commands, unexpected new connections, port scans
Asset/Endpoint	Engineering workstations, HMIs, historian servers, domain controllers in OT zone	Agent-based (where supported); agentless where not — via WMI/WinRM from read-only account	Process changes, USB insertions, unusual logins, software installations, project file modifications
Application/SCADA	SCADA servers, historian (OSIsoft PI, GE Proficy, AspenTech), OPC servers	Syslog forwarding, OPC-UA event subscription, REST API where available	Operator actions, setpoint changes, alarm state changes, failed logins, recipe changes
Process Data	DCS historian, process data infrastructure	Read-only historian query; OSIsoft PI EventFrames; process value deviation detection	Out-of-band process values, sudden value changes, sensor flatlines (potential spoofing indicator)
Identity & Access	Active Directory (OT zone), remote access gateway, vendor jump servers	AD event log collection; VPN authentication logs; PAM session recording	Failed authentications, privilege escalation, off-hours vendor access, shared credential use

3.3 Technology Stack — Recommended Components

The following technology stack represents a tested, deployable OT SOC architecture. Products are categorised by function; specific vendor selection should be validated against the organisation's OT protocol mix, existing IT tooling, and regulatory requirements.

3.3.1 OT-Native Network Detection and Response (NDR)

This is the core detection capability for any OT SOC. Unlike generic network monitoring tools, OT-native NDR platforms understand industrial protocols at the function code level — they can identify not just that a Modbus message was sent, but what specific coil or register was read or written, by which device, and whether that specific operation is normal for this time of day and this source/destination pair.

Deployment requirement: Passive SPAN port access to all critical OT network segments is mandatory. Without SPAN coverage of the cell/area zone (Purdue Level 1–2), the NDR platform cannot see controller-level communications — the most important telemetry for OT threat detection.

3.3.2 SIEM — OT-Contextualised Correlation

The SIEM is the correlation and case management backbone. Two deployment approaches are validated: (a) extending the existing enterprise SIEM with dedicated OT data feeds and rule sets, or (b) deploying a separate OT-specific SIEM instance that forwards high-confidence alerts to the enterprise SIEM for consolidated visibility. For organisations at scale (>1,000 OT assets), option (b) is strongly recommended because OT data volumes and protocol parsing requirements often overwhelm shared SIEM infrastructure.

Critical configuration requirement: The SIEM must have OT asset context built in — asset type, engineering zone, owning process, normal communication baselines, and criticality classification. An alert about a PLC communicating to an unknown IP address requires immediate context about what that PLC controls before an analyst can judge severity.

3.3.3 OT Asset Inventory and Vulnerability Management

Effective SOC operations depend on an accurate, continuously updated asset inventory. In OT environments this is significantly harder than in IT because: (a) many devices do not respond to discovery queries; (b) active scanning can cause device resets or communication disruptions; (c) asset lifecycles span decades and documentation is often incomplete. The asset inventory must be populated through passive network observation (the NDR platform is the primary source), supplemented by manual walkthroughs and P&ID cross-referencing.

3.3.4 Remote Access Security — A Non-Negotiable Control

Third-party remote access is the highest-risk entry vector in most OT environments. Every organisation that has suffered a significant OT security incident attributable to external access has, on investigation, revealed inadequate controls: shared credentials, always-on VPN connections, no session recording, no multi-factor authentication, no time-limited access

windows. The OT SOC must have visibility into all remote access sessions in real time and must be able to terminate sessions immediately.

Minimum required controls: MFA on all remote access; dedicated jump server with session recording; time-limited access credentials; SOC analyst approval required for any unscheduled vendor access; full session video recording retained for minimum 12 months.

3.3.5 OT Threat Intelligence Platform

OT threat intelligence is a specialist capability that generic threat intel platforms do not adequately serve. The OT SOC requires access to: sector-specific ISAC feeds (Shieldworkz); ICS-specific CVE and vulnerability databases (Shieldworkz Threat Research); vendor-specific security advisories for the DCS, PLC, and SCADA platforms in the environment; and curated intelligence on OT-targeting threat groups including ELECTRUM, SANDWORM, XENOTIME, and KAMACITE.

4. OPERATIONAL GOALS AND MISSION FRAMEWORK

4.1 OT SOC Mission Statement

The OT SOC mission must be stated explicitly, communicated to all stakeholders, and reviewed annually. The following mission statement has been refined across multiple operational deployments and represents the balance between security efficacy and operational partnership that sustains an OT SOC long-term.

"To provide continuous, safety-conscious detection of and response to cyber threats targeting operational technology environments, protecting the availability and integrity of industrial processes, enabling regulatory compliance, and providing our Operations and Engineering teams with the actionable intelligence they need to make risk-informed decisions — while at all times subordinating security actions to the primacy of process safety and operational continuity."

4.2 Strategic Operational Goals — Hierarchy

Operational goals must be organised in priority order. In an OT environment, the order matters — when goals conflict, the higher priority goal prevails. This hierarchy should be documented in the SOC charter and reviewed with all analysts during onboarding.

1. **SAFETY INTEGRITY: No SOC action shall create or worsen a safety hazard. All response playbooks include a safety impact assessment step before any containment or isolation action is taken. If the safety impact of an action is uncertain, escalate to the Process Safety team before proceeding.**
2. **PROCESS AVAILABILITY:** Preserve the continuity of critical OT processes. Detection and response activities default to observation-and-advise mode rather than automated intervention. Automated response actions require explicit Engineering approval for each specific action type.
3. **THREAT DETECTION:** Achieve and maintain the broadest possible detection coverage across all OT zones, with particular depth in the cell/area zone (Purdue L1–L2) where field controllers reside.
4. **VALIDATED RESPONSE:** Respond to confirmed threats with speed and precision, using pre-validated playbooks that have been reviewed by Operations and Engineering before operational deployment.
5. **INTELLIGENCE GENERATION:** Transform detection and investigation findings into actionable intelligence that improves future detection, informs risk management, and contributes to sector-level awareness through appropriate ISAC participation.
6. **REGULATORY ASSURANCE:** Maintain the evidence, documentation, and reporting capability required to demonstrate compliance with applicable regulations (NERC CIP, NIS2, IEC 62443, sector-specific requirements).

4.3 Use Case Library — OT SOC Detection Coverage

The OT SOC use case library defines the detection scenarios for which specific rules, baselines, and alert workflows are developed and maintained. The following represents a production-validated use case library organised by threat category. Each use case must have an assigned owner, defined data sources, tuned detection logic, validated playbook, and documented false positive baseline.

Use Case	Category	Primary Data Source	Key Detection Logic
New device appeared on OT network	Asset Discovery	OT NDR passive scan	MAC/IP not in asset inventory; first-seen timestamp; zone classification
PLC receiving write commands from unknown source	Unauthorised Command	OT NDR — Modbus/EIP/DNP3 parser	Function code 6/16 (write) from IP not in approved engineering workstation list
Engineering workstation communicating to internet	Exfiltration / C2	Firewall + NDR	Outbound connection from EWS to non-approved destination; unusual port; encrypted beaconing
Remote access session outside approved window	Unauthorised Access	VPN / Jump server logs	Session initiated outside change window; no associated change ticket; vendor not scheduled
USB/removable media insertion on OT endpoint	Media Control	Endpoint agent / Windows event log	DeviceSetupManager event 20003; USB device ID not in approved list
Mass authentication failures in OT Active Directory	Brute Force / Credential Attack	AD event logs (Event ID 4625)	More than 5 failures in 60 seconds from single source against OT accounts
Historian server communicating with OT field devices directly	Network Anomaly / Lateral Movement	OT NDR	Direct historian-to-PLC connection outside of normal data collection path; could indicate compromised historian being used as pivot
DCS project file modification outside change window	Configuration Tampering	File integrity monitoring / SCADA application logs	Hash change on .dcs/.proj/.rss file; modification timestamp outside approved maintenance window
Process value outside safe operating envelope (security-triggered)	Process Safety Indicator	Historian / process data feed	Correlated with concurrent security event; distinguish from pure process fault through concurrent network anomaly
Safety system (SIS) communication anomaly	Safety System Threat	OT NDR — Safety bus monitoring	Any command directed at SIS logic controller from non-approved source; any attempt to modify SIS logic
OPC-UA server accepting anonymous connections	Misconfiguration / Vulnerability	OPC-UA session log	Session established without authentication; source IP outside approved historian/SCADA servers

Use Case	Category	Primary Data Source	Key Detection Logic
Lateral movement: IT to OT zone crossing	Boundary Violation	Firewall + NDR	Connection crossing Purdue L3.5/L3 boundary not matching approved application list; timing correlation with IT security alert

5. OT SOC KPIS, METRICS AND PERFORMANCE FRAMEWORK

5.1 The OT SOC Measurement Philosophy

Metrics are only valuable if they drive decisions. Too many OT SOC measure what is easy to count — number of alerts, tickets closed, mean time to acknowledge — rather than what matters operationally. The framework below distinguishes between three classes of metric: Leading Indicators (predictive of future security posture), Lagging Indicators (measuring past performance), and Operational Health Indicators (measuring SOC sustainability and effectiveness). All three are required for a complete picture.

5.2 Tier-1: Executive and Board-Level KPIs (CISO Dashboard)

These metrics are designed for board-level reporting, CISO dashboards, and regulator submissions. They must be reported monthly at minimum, with quarterly trend analysis.

KPI	Target	Class	Operational Meaning
OT Asset Inventory Coverage	>98% of known assets	Leading	Percentage of known OT assets for which the SOC has at least one active telemetry source. Cannot detect what you cannot see.
Detection Coverage by Use Case	>95% use cases active	Leading	Proportion of defined use cases with validated, active detection rules producing at least one test trigger per quarter.
Mean Time to Detect (MTTD)	<4 hours for High/Critical	Lagging	Time from adversary action (as established in post-incident review) to first SOC alert. The gold standard OT target is <1 hour for known TTP signatures.
Mean Time to Respond (MTTR)	<1 hour for Critical; <4 hours for High	Lagging	Time from confirmed incident declaration to first validated containment action. Safety assessment time excluded from SLA if safety impact assessment triggered.
False Positive Rate by Alert Category	<15% overall; <5% for Critical	Operational	Percentage of alerts that are closed as false positives. High false positive rates erode analyst trust, cause alert fatigue, and result in real threats being missed.
Incidents Contained Without Production Impact	>90% of incidents	Lagging	Proportion of confirmed security incidents that were contained without requiring an unplanned production shutdown or safety system activation.

KPI	Target	Class	Operational Meaning
Playbook Coverage (Confirmed Incident Types)	100% of incident types	Leading	Every incident type for which the SOC has declared a confirmed case must have a validated playbook within 30 days of closure.
Regulatory Compliance Evidence Availability	100% on-demand	Operational	Ability to produce required evidence (log retention, access records, incident reports) within regulatory timeframes on demand.

5.3 Tier-2: Operational KPIs (SOC Lead Dashboard)

These metrics are monitored weekly by the SOC Lead and monthly by the CISO. They measure the operational effectiveness and efficiency of the SOC team.

Metric	Target	Notes and Guidance
Alert Volume Trend	Decreasing or stable	Increasing alert volume without increasing incident rate indicates tuning debt. Schedule rule review if >20% increase in 30 days with no change in OT environment.
Mean Time to Acknowledge (MTTA)	<15 min for Critical; <30 min for High	Clock starts when alert fires in SIEM. Consistently exceeded MTTA indicates understaffing or alert queue overload.
Analyst Utilisation Rate	65–80%	Below 65%: overstaffed or under-alerting. Above 80%: analysts burning out, quality of investigation declining. Either extreme is a risk indicator.
Threat Hunt Campaigns Completed per Quarter	>2 per quarter	Proactive hunting is the only mechanism to detect pre-positioned threats that have not triggered reactive detection rules. Two minimum; four recommended for high-risk sectors.
New Use Cases Developed per Quarter	>1 per quarter	OT threat landscape evolves. SOC that does not add new use cases is falling behind. Minimum one per quarter; source from threat intel, incident post-mortems, and red team findings.
Sensor/Collector Uptime	>99.5%	Each monitoring gap is a detection blind spot. OT network changes, power cycling of OT switches, and SPAN port misconfiguration are common causes of sensor dropout — often undetected.
Vendor Access Sessions Audited	100%	Every third-party remote access session must be reviewed for anomalous activity within 24 hours of session completion.
Incident Post-Mortem Completion Rate	100% within 5 days	Every confirmed incident requires a post-mortem. The root cause and gap analysis from post-mortems is the primary quality improvement mechanism for the SOC.

5.4 Tier-3: Technical and Analyst-Level Metrics

Monitored daily by SOC analysts and weekly by the SOC Lead. These metrics keep the SOC technically healthy.

- SIEM ingestion lag: time between event generation and SIEM availability — target <2 minutes for real-time sources, <15 minutes for batch sources
- SPAN coverage completeness: percentage of OT network segments actively spanned to NDR sensor — target 100% of critical segments (L1/L2 minimum)
- Asset inventory staleness: percentage of assets not seen on network in last 7 days — investigate any OT asset not seen in 72 hours
- Correlation rule failure rate: rules that fired zero alerts in 30 days despite matching data existing — indicates rule logic error or data source failure
- Playbook adherence rate: percentage of incidents where documented playbook steps were followed — target >95%; deviations require documented justification
- Training completion rate: percentage of analysts current on required OT SOC training and certifications — target 100%
- Threat intelligence feed currency: age of most recent OT-specific threat intelligence update actioned into detection rules — target <7 days lag

6. OT INCIDENT RESPONSE — PLAYBOOK FRAMEWORK

6.1 The OT IR Doctrine — Safety Before Speed

IT incident response doctrine is built around speed: contain fast, eradicate fast, recover fast. OT incident response doctrine is built around safety: assess safety impact before every action, contain only when containment does not create a more dangerous state, and recover in coordination with Operations and Engineering. The following four-gate model governs every OT incident response action.

Gate	Name	Question to Answer	Decision Authority
G1	Safety Assessment	Does this incident create or worsen a physical safety risk? Does any proposed response action create or worsen a safety risk?	Process Safety Engineer — mandatory consultation; SOC cannot proceed to containment without documented safety assessment
G2	Process Impact Assessment	What is the consequence of the incident continuing? What is the consequence of our proposed response action on the running process?	Operations Lead / Control Room Supervisor — jointly with SOC T3
G3	Containment Decision	What is the minimum viable containment action that stops threat progression without unacceptable process impact? Is the action reversible?	SOC Lead + Operations Lead — documented in incident record
G4	Recovery Coordination	Has the threat been fully remediated? Is the environment safe to return to normal operation? What monitoring is required post-recovery?	CISO / Plant Manager — formal sign-off on return to service

6.2 OT Incident Severity Classification

The OT incident severity model must be distinct from the IT model. Severity in OT is defined by potential physical consequence, not data value. The following matrix is the recommended OT-specific severity classification.

Level	Name	Definition	Examples	Response SLA
SEV1	SAFETY CRITICAL	Active threat to physical safety of personnel, potential for environmental release, SIS compromise confirmed or highly probable	TRITON-type attack on SIS; ransomware on DCS during live production; active manipulation of safety setpoints	Immediate — all hands; executive notification within 15 minutes; regulatory notification within 1 hour

Level	Name	Definition	Examples	Response SLA
SEV2	PRODUCTION CRITICAL	Confirmed compromise of OT system with capability to impact production; active lateral movement in OT zone; containment action will affect production	Ransomware on historian; compromised EWS with live PLC connections; active C2 communication from SCADA server	15-minute escalation to T3 + SOC Lead; Operations notified within 30 minutes; CISO briefed within 1 hour
SEV3	OT ZONE COMPROMISE	Confirmed malicious presence in OT network, not yet demonstrating capability or intent to affect process; policy violation with OT scope	Malware on isolated EWS (offline); successful phishing of OT engineer; new rogue device on OT network with C2 indicators	1-hour investigation; Operations informed; CISO notified same business day
SEV4	ANOMALY / POLICY VIOLATION	Suspicious activity or policy violation in OT environment without confirmed malicious intent	Unauthorised USB use; misconfigured remote access; IT device found on OT network without clear compromise	4-hour investigation; standard ticket workflow; weekly SOC report inclusion
SEV5	INFORMATIONAL	Events requiring documentation and awareness but no active response	ISAC advisory with no immediate applicability; vendor patch release; configuration drift detected within approved range	Document in knowledge base; action within next maintenance window as appropriate

6.3 Master Playbook — Ransomware in OT Environment

Ransomware targeting OT environments is the highest-frequency severe incident type. The following playbook represents the consolidated response procedure validated across multiple real-world OT ransomware incidents. Each step must be executed in sequence. No step may be skipped without documented justification.

Phase 1: Detection and Initial Triage (T+0 to T+15 minutes)

1. Alert fires — analyst identifies ransomware indicators: encryption activity in file I/O monitoring, ransom note file creation, process behaviour indicative of ransomware (vssadmin.exe shadow copy deletion, rapid file extension changes)
2. Immediate asset identification: What OT systems are affected? What do those systems control? Consult asset inventory immediately — do not attempt containment until this is known
3. Escalate to T3 and SOC Lead immediately. If affected systems include any historian, SCADA server, EWS, or any system within Purdue L0-L2, escalate to CISO and invoke SEV2 minimum
4. Contact Control Room: notify Operations Supervisor that a security incident is in progress. Do NOT disclose attack details at this stage — advise them to increase

manual observation of process parameters and be prepared for potential manual operation

Phase 2: Safety Assessment (T+15 to T+30 minutes)

1. Invoke Safety Gate G1: conference call with Process Safety Engineer. Review: Is the affected system a safety-critical system? Is the process currently in a state where losing the affected system would create a safety hazard?
2. Document safety assessment outcome. If Safety Engineer determines that the system in question cannot be isolated without safety consequence, do NOT isolate. Maintain monitoring only. Escalate to Plant Manager for decision on controlled shutdown if required.
3. Establish out-of-band communication with Control Room. Do not rely on the OT network for incident communication — it may be compromised or affected. Use radio, phone, or physically present SOC analyst in Control Room.

Phase 3: Containment (T+30 to T+90 minutes — safety-cleared only)

1. Network isolation of affected systems — execute ONLY for systems cleared by Safety Gate. Use pre-configured firewall ACL changes to quarantine affected VLAN/zone. Do not unplug physical cables on live field devices.
2. Identify propagation path: How did ransomware reach OT? Review IT/OT boundary firewall logs. Check for east-west movement within OT zone. Block identified propagation path at boundary firewall.
3. Disable or revoke any external access credentials that may have been the initial access vector. Coordinate with vendor if vendor access is suspected.
4. Preserve forensic evidence before beginning remediation: memory capture of affected systems where possible, full disk image of affected OT servers, NDR packet capture of the infection timeframe.

Phase 4: Eradication and Recovery (T+90 minutes onwards)

1. DO NOT restore from backup without first validating backup integrity and confirming the backup predates the initial compromise, not just the ransomware trigger. Advanced attackers pre-position weeks or months before deploying ransomware.
2. Restore OT systems from known-good images or vendor-supplied firmware. Validate restored PLC/DCS logic against last known-good project file backup — do not assume the project file backup is clean without hash verification against a reference.
3. Conduct full system validation testing before returning to live process operation. This must be conducted in conjunction with Operations and Engineering — do not return a system to service on security clearance alone.
4. Post-incident monitoring: deploy enhanced logging on all previously affected systems for minimum 90 days post-recovery. Schedule threat hunt within 30 days to confirm no secondary persistence.

7. SECURITY CONTROLS FRAMEWORK — OT SOC APPLICATION

7.1 Controls Architecture — The Defence-in-Depth Model for OT

The OT SOC does not operate in isolation — it is the sensing and response layer that sits atop a controls architecture. If the underlying controls are weak, the SOC is overwhelmed with low-quality alerts and struggles to distinguish real threats from noise. CISOs must ensure that the defensive controls below are implemented before expecting the SOC to function effectively.

Controls Reality Check

An OT SOC built on a weak controls foundation will generate more work than it resolves. Organisations frequently deploy expensive monitoring tooling on networks with no segmentation, no identity controls, and no patch management — then wonder why the SOC produces an unmanageable alert volume. The sequencing of investment matters: controls first, monitoring second, SOC third.

7.2 Preventive Controls — The SOC's Prerequisites

Control	Priority	IEC 62443 Ref.	OT SOC Dependency
Network Zone Segmentation (Purdue model or ISA-95)	Critical	SR 5.1, SR 5.2	Without zone segmentation, lateral movement is unrestricted and the SOC cannot establish baseline communication patterns. Segmentation creates the anomaly detection foundation.
IT/OT Boundary Firewall with Default-Deny policy	Critical	SR 5.1	The boundary firewall is the SOC's most important chokepoint for detecting IT-to-OT lateral movement. Permissive boundary = overwhelming alert volume for benign traffic.
OT Asset Inventory (continuously maintained)	Critical	SR 1.1	The SOC cannot classify alerts without knowing what the asset is. Stale inventory = alert context failure = slow triage = delayed response.
Privileged Access Management (PAM) for OT accounts	High	SR 1.1, SR 1.2	Compromised OT privileged accounts are the primary means of OT manipulation. SOC must receive PAM session logs for all privileged access.
Multi-Factor Authentication for all remote access	Critical	SR 1.7	Single-factor remote access is an unacceptable residual risk in any OT environment with remote access capability. MFA implementation is a SOC detection prerequisite.
Removable Media Control Policy + Technical Enforcement	High	SR 2.3	USB-delivered malware is a leading initial access vector in air-gapped and semi-isolated OT environments. USB whitelist

Control	Priority	IEC 62443 Ref.	OT SOC Dependency
			enforcement reduces alert noise significantly.
OT-specific Antivirus / Application Allowlisting on EWS	High	SR 3.2	Application allowlisting on engineering workstations is far more effective than signature AV in OT environments. Allowlist generates high-fidelity alerts for any unauthorised execution.
OT Vulnerability Assessment (passive, scheduled)	High	SR 3.3	The SOC must know the vulnerability exposure of the OT environment to prioritise detections correctly. A critical CVE on an internet-facing OT server changes the alert severity model.

7.3 Detective Controls — The SOC's Primary Toolkit

Detective controls are the SOC's operational territory. The following matrix maps detective controls to the specific threat categories they address, with implementation guidance drawn from field deployment experience.

Control	Threat Category Addressed	Detection Quality	Field Implementation Note
OT NDR — Passive Network Monitoring	All OT-native threat categories	High for known TTPs; Medium for novel	Deploy sensor per zone pair, not per zone. Ensure SPAN covers inter-zone traffic at the zone boundary switch, not just internal switch ports.
OT-tuned SIEM with process context	Correlation across sources; supply chain; insider	High when properly tuned	Plan 6 months of tuning time post-deployment before expecting production-quality alert fidelity. Use OT asset context in every correlation rule.
File Integrity Monitoring on EWS and DCS servers	Logic modification; ransomware; insider	Very High for targeted attacks	Monitor PLC project file directories specifically. Any hash change outside a change window is a high-confidence indicator requiring immediate investigation.
Process Data Anomaly Detection	Safety system attacks; process manipulation	Medium (high false positive potential)	Correlation with security events is essential — standalone process anomaly alerting generates too much noise from legitimate process variability. Use as enrichment, not primary detection.
Honeypots and Deception Technology (OT-specific)	Reconnaissance; lateral movement; insider	Very High (near-zero false positive)	Deploy OT honeypots as fake PLCs, RTUs, and HMIs using real OT protocol stacks. Any interaction with a honeypot is high-confidence malicious.

Control	Threat Category Addressed	Detection Quality	Field Implementation Note
			Requires OT expertise to configure convincingly.
Wireless Intrusion Detection (for OT wireless networks)	Rogue AP; wireless protocol attacks; physical intrusion	High	Often overlooked. Many OT environments have wireless networks for field device communications (WirelessHART, ISA100.11a) that are inadequately monitored.

7.4 Responsive Controls — SOC Execution Toolkit

Responsive controls are those the SOC can execute during an active incident. Each must be pre-validated with Operations and Engineering before operational deployment. A response action that has not been tested in the specific OT environment must never be executed during a live incident — the consequences of an untested action can exceed the consequences of the incident itself.

- Network quarantine via pre-configured firewall ACL — tested for each OT network segment; safety impact of quarantining each segment documented
- Remote access session termination — SOC must have break-glass authority to terminate any remote session without requiring approval (approval required to re-establish)
- Credential revocation in OT Active Directory — pre-authorised for OT security accounts; requires documented sign-off from OT Operations Lead for shared service accounts
- Process historian data preservation — automated snapshot capability that does not interfere with live data collection; activated at SEV2+ to preserve pre-incident process baseline
- Out-of-band communication activation — dedicated communication channel (radio, cellular, physical runner) for Control Room coordination that bypasses potentially compromised OT network
- Vendor access lockdown — global disable of vendor remote access accounts pending investigation; requires documented exception process for safety-critical maintenance

8. RESIDUAL RISK FRAMEWORK — HONEST ACCOUNTING

8.1 Why Residual Risk Must Be Explicitly Documented

Every OT SOC operates with residual risk. No monitoring capability is complete. No detection is instantaneous. No response is without consequence. CISOs and security leaders who present their OT SOC as a complete solution are either misinformed or misleading their boards. The professional obligation is to document, quantify, and formally accept residual risks — and to ensure that acceptance is made by someone with the authority and context to understand the consequences.

Board Communication Standard

The residual risk register is the OT SOC's most important governance document. It should be reviewed by the CISO quarterly, presented to the Risk Committee semi-annually, and updated within 30 days of any significant change to the threat landscape, OT environment, or SOC capability. Any risk that has been accepted for more than 12 months without documented review represents a governance failure.

8.2 Inherent Residual Risks in OT SOC Operations

The following residual risks are inherent to OT SOC operations and cannot be fully eliminated by any combination of technology and process. They can only be reduced, mitigated, and accepted with appropriate compensating controls.

Residual Risk	Inherent Likelihood	Inherent Impact	Mitigation and Compensating Controls
Legacy OT device blind spots: devices that cannot support any monitoring agent and produce no network logs — the SOC has zero visibility into their internal state	High	High	Deploy deception technology around legacy assets; monitor all ingress/egress traffic to legacy device segments; implement strict physical security; schedule asset replacement in capital planning
Zero-day exploits targeting OT protocols or specific PLC firmware — no signature or behavioural rule exists at time of attack	Low-Medium (elevated for high-profile targets)	Critical	Behavioural baselining detects deviations even from novel attacks; threat hunting actively searches for pre-positioning indicators; network segmentation limits blast radius
Insider threat from privileged OT user with physical access — SOC cannot monitor all physical interactions with field equipment	Low	Critical	PAM session recording; dual-person integrity for safety-critical changes; process data monitoring for unexplained value changes; physical security integration (CCTV, access control integration)
Response action delay due to safety	High (by design)	Medium-High	Pre-validate and pre-authorise response actions for each zone/system type; pre-

Residual Risk	Inherent Likelihood	Inherent Impact	Mitigation and Compensating Controls
assessment requirement — by design, the SOC cannot act at IT speeds in OT environments			position designated safety engineers on incident response roster; run quarterly tabletop exercises to reduce gate-passage time
Supply chain implants in OT hardware or firmware — malicious code delivered through legitimate vendor update or hardware supply chain	Low-Medium (nation-state targets)	Critical	Vendor firmware verification programme; software composition analysis for updates before deployment; SBOM requirements in new procurement; dedicated OT update management process separate from IT patch management
Air-gap bridging via RF channels or optical side channels — attacker uses out-of-band covert channel to communicate with implant in air-gapped OT network	Very Low (advanced nation-state)	Critical for air-gapped environments	Faraday shielding in highest-security zones; electromagnetic emissions monitoring; strict removable media and mobile device policy; physical intrusion detection
Analyst cognitive overload / alert fatigue leading to missed real incident	High (poorly tuned SOC)	High	Enforce false positive rate targets (<15%); mandatory shift time limits for T1 analysts; dual-analyst review for all Critical alerts; mandatory breaks enforced in shift schedule; quarterly rule tuning reviews
IT/OT boundary erosion through incremental change — each individual connectivity change is approved, but the cumulative effect creates unintended pathways	High	High	Quarterly boundary review comparing current firewall policy to intended architecture; automated change management integration to SOC change log; zone-crossing traffic trending analysis
Monitoring coverage gap during maintenance windows — SPAN ports disconnected, sensors powered down, or firewall rules modified during maintenance	Medium	Medium	SOC notified of all maintenance activities affecting monitoring infrastructure minimum 72 hours in advance; compensating monitoring deployed before maintenance window opens; post-maintenance sensor validation checklist

8.3 Quantified Risk Acceptance Framework

Each residual risk must be formally quantified and accepted. The following framework provides a repeatable process for risk quantification in OT environments, adapted from the FAIR (Factor Analysis of Information Risk) methodology with OT-specific consequence categories.

Consequence Categories for OT Risk Quantification

- Safety consequence: probability-weighted expected harm to personnel (injury/fatality frequency; severity per IEC 61511 process safety risk matrix)
- Environmental consequence: probability-weighted expected environmental release volume and duration (reportable threshold, regulatory fine exposure, remediation cost)
- Production impact: expected production loss in revenue terms (throughput per hour x expected outage duration x product margin)
- Regulatory consequence: probability of regulatory action x expected fine/sanction quantum x licence risk premium
- Reputational consequence: customer/stakeholder confidence impact — quantified through brand value models or insurance premium movement

Risk Acceptance Authority Guidance

Residual risks with potential safety consequences must never be accepted below the Plant Manager and CISO level. Risks with potential for environmental release must include the HSE/EHS function. Risks with a quantified consequence above the organisation's defined risk appetite threshold require board Risk Committee sign-off. This is not bureaucracy — it is the minimum accountability framework required for an honest risk management programme.

9. GOVERNANCE, COMPLIANCE AND REGULATORY ALIGNMENT

9.1 OT SOC Governance Charter — Minimum Requirements

The OT SOC must operate under a formal governance charter that is reviewed and signed by the CISO and the Head of Operations annually. The charter defines the SOC's authority, its boundaries, its reporting lines, and the decision rights that govern the interface between security operations and OT operations. Without a charter, the SOC operates in ambiguity — and in a crisis, ambiguity costs time.

The charter must address the following at minimum:

- **Mission, scope, and out-of-scope boundaries**
- Reporting lines: SOC Lead reports to CISO; CISO provides dotted-line reporting to Head of Operations for OT-impacting decisions
- Decision authority matrix: who can authorise network isolation, credential revocation, vendor lockout, and controlled shutdown recommendation
- Interface agreements with Operations: escalation path, contact roster, Control Room notification protocol, Operations right of veto on containment actions
- Interface agreements with IT SOC: shared tooling governance, escalation protocol for IT-origin OT incidents, data sharing boundaries
- Budget authority: SOC Lead must have dedicated OT SOC budget line — tools, training, threat intelligence subscriptions, and external incident response retainer
- Performance review: quarterly KPI review with CISO; annual programme review with board Risk Committee

9.2 Regulatory Framework Cross-Reference

The OT SOC supports compliance with multiple regulatory frameworks simultaneously. The following matrix identifies the key requirements each framework places on the SOC function.

Framework	Key SOC-Relevant Requirements	SOC Capability Required	Evidence Artefact
IEC 62443-2-4 / 3-3	Security monitoring and incident detection at each security level; documented response procedures; change management integration	OT NDR, SIEM with OT context, validated playbooks, change management integration	Monitoring architecture documentation; use case register; playbook library; change log integration records
NERC CIP (CIP-007, CIP-008, CIP-010)	Security event monitoring for High/Medium impact BES Cyber Systems; 90-day log retention minimum; incident response plan; change management controls	SIEM with 90-day+ log retention; incident response plan tested annually; configuration change monitoring	Log retention compliance report; IR plan with test results; CIP-010 change inventory; CIP-007 port/service review

Framework	Key SOC-Relevant Requirements	SOC Capability Required	Evidence Artefact
NIS2 Directive (EU)	Incident detection and reporting within 24 hours of awareness; multi-year incident history; supply chain security measures; management accountability	24-hour incident detection SLA; incident reporting workflow to national CSIRT; supply chain monitoring capability	Incident notification records; CSIRT communication log; supply chain risk register; management training records
NIST CSF 2.0	Detect function: continuous monitoring; Respond function: incident response plan; Recover function: recovery planning and communications	Continuous monitoring across all five tiers; playbook library; recovery runbooks with Operations	CSF maturity assessment; monitoring coverage report; playbook inventory; recovery plan documentation
UK CNI Cyber Assessment Framework (CAF)	Objective C: Detect — security monitoring of network and systems; Objective D: Minimise impact — response and recovery	Network monitoring; endpoint monitoring; anomaly detection; tested response capabilities	CAF self-assessment evidence pack; monitoring tool documentation; incident response test results

9.3 OT SOC Maturity Model

The following five-level maturity model provides a structured roadmap for OT SOC development. Each level builds on the previous — organisations attempting to jump levels without completing prerequisite capabilities consistently encounter the same failure modes.

Level	Maturity	Defining Characteristics	Transition Requirements
L1	Initial	Ad hoc incident response; no dedicated OT SOC; OT security events managed by IT SOC or not managed at all; no OT-specific monitoring	Establish OT asset inventory; implement network segmentation; deploy initial OT NDR sensor on critical segment; designate OT security owner
L2	Developing	Basic OT monitoring deployed; alerts reaching IT SIEM; informal OT security process; at least one trained OT security analyst; initial playbooks for top 5 scenarios	Achieve 80% asset inventory coverage; deploy SOC governance charter; develop 10+ validated use cases; conduct first tabletop exercise with Operations
L3	Defined	Formal OT SOC capability; dedicated analyst resources; defined tier structure; validated playbook library covering all incident types; regular threat hunting; ISAC participation; KPI reporting	Achieve MTTD <4 hours; false positive rate <20%; full shift coverage model; threat hunting programme active; regulatory compliance evidence package complete
L4	Managed	Metrics-driven continuous improvement; regular red team / purple team exercises; threat intelligence actively tuning detection; automated playbook	MTTD <1 hour for known TTPs; false positive rate <10%; quarterly red/purple team programme; SOAR automation for tier-1 playbooks; formal residual risk register maintained

Level	Maturity	Defining Characteristics	Transition Requirements
		execution for low-risk scenarios; board-level risk reporting	
L5	Optimising	Predictive threat detection using ML-enhanced behavioural analytics; sector-leading threat intelligence production; continuous automated validation of detection coverage; zero tolerance for governance gaps; industry-recognised capability	AI-augmented analyst tooling; automated detection validation programme; ISAC leadership / threat intelligence contribution; external capability assessment scoring top quartile

10. CISO AND SECURITY LEADER ACTION GUIDE

10.1 The 90-Day OT SOC Launch Programme

For CISOs who are establishing or significantly reforming an OT SOC, the following 90-day programme provides a structured launch sequence. Each phase has defined deliverables that gate progression to the next phase.

Days 1–30: Foundation and Assessment

1. Commission an independent OT security assessment to establish the current asset inventory, network topology, existing monitoring coverage, and control gap analysis. Do not begin SOC design without this baseline.
2. Establish the OT SOC governance charter. Secure signatures from CISO, Head of Operations, and Plant/Site Manager. Define the decision authority matrix before any monitoring tool is deployed.
3. Define the SOC model appropriate to the organisation's size, risk profile, and budget. Document the rationale. If the decision involves outsourcing, begin MSSP RFP process immediately — vendor selection takes 60–90 days minimum.
4. Identify and begin recruiting/developing the SOC leadership role (OT SOC Lead). This person is the critical success factor — the wrong appointment will set the programme back 18 months.
5. Engage Operations and Engineering leadership. Present the SOC mission and explicitly seek their partnership. Establish a joint OT SOC steering group with Operations representation.

Days 31–60: Technology and Process

1. Deploy initial OT NDR sensor on the highest-priority network segment — the segment containing the most critical field controllers. Prioritise coverage quality over coverage breadth in the first deployment phase.
2. Configure SIEM data feeds for OT NDR, boundary firewall, engineering workstation event logs, and remote access gateway. Develop initial 10 use cases from the use case library in this document. Deploy and validate each.
3. Develop and validate the top-5 incident playbooks (ransomware, unauthorised remote access, new rogue device, EWS compromise, process data anomaly). Test each playbook in tabletop format with Operations and Engineering.
4. Establish the initial OT asset inventory within the SOC platform. Target 80% known-asset coverage by end of Day 60.
5. Subscribe to relevant ISAC intelligence feeds and configure delivery into SOC analyst workflow. Begin tracking OT-relevant threat actor activity.

Days 61–90: Operationalisation and Governance

1. Stand up the SOC analyst function with defined shift coverage. Conduct a 2-week parallel-run where experienced staff shadow analysts to validate alert triage quality before full handover.

2. Conduct the first full tabletop exercise simulating an OT ransomware scenario. Include Control Room staff, Operations management, CISO, and external incident response retainer (if contracted). Document findings and incorporate into playbooks.
3. Publish the first SOC KPI dashboard to CISO and Operations leadership. Establish the reporting cadence: weekly operational metrics, monthly CISO review, quarterly board reporting.
4. Complete and publish the initial residual risk register. Conduct formal risk acceptance meeting with CISO and Head of Operations. Document all accepted risks and compensating controls.
5. Conduct a gap assessment against the target maturity level and document a 12-month improvement roadmap with specific milestones, owners, and budget requirements.

10.2 The Five Questions Every CISO Must Be Able to Answer

CISOs responsible for OT SOC programmes will face these questions from boards, regulators, and insurers. If the answer to any of them is uncertain, it identifies a gap that requires immediate attention.

Question	What a Strong Answer Looks Like
If an attacker is actively moving through our OT network right now, how long would it take us to know?	Specific MTTD figure supported by detection coverage data; honest acknowledgement of any blind spots; compensating controls for those blind spots named
If a ransomware attack encrypted our SCADA servers tonight, what would we do in the first 30 minutes?	Reference to tested playbook with named individuals; specific decision authority named; operations notification protocol described; retainer IR firm named
What are the three things most likely to cause a significant OT security incident, and what are we doing about each?	Specific OT risk register entries; current mitigation status; residual risk level; risk owner named
What would an attacker who had compromised one of our engineering workstations be able to do?	Specific answer based on actual EWS connectivity and privilege mapping; compensating controls named; detection capability described
When did we last test our OT incident response capability, and what did we learn?	Specific exercise date; named findings; remediation actions; next exercise date scheduled

11. APPENDIX — REFERENCE MATERIALS AND TEMPLATES

11.1 OT SOC Technology Selection Criteria

Use the following evaluation criteria when selecting OT SOC technology. Each criterion should be scored 1–5 and weighted by organisational priority.

- **OT protocol support breadth: does the platform natively parse the specific protocols in your environment (not just common ones — ask specifically about your DCS vendor's proprietary protocols)**
- **Passive-only collection capability:** can the platform operate entirely passively with zero active queries sent to OT devices
- **Asset inventory auto-population:** how accurately does the platform identify and classify OT assets from passive observation alone
- **Integration with existing SIEM/SOAR:** what is the maturity and fidelity of the integration; does it forward raw events or correlated alerts
- **Scalability to site count and asset volume:** validated performance data at your anticipated scale, not vendor claims
- **Vendor OT expertise:** assess the vendor's actual OT/ICS team depth, not their marketing materials
- **Geographic deployment options:** on-premise, cloud-connected, or air-gapped deployment; jurisdiction of data residency
- **Threat intelligence integration:** frequency and specificity of OT threat intelligence updates; named threat group tracking

11.2 OT SOC Programme Budget Planning Reference

The following budget structure reflects validated programme costs across multiple OT SOC deployments. All figures are indicative ranges for planning purposes; actual costs vary significantly by organisation size, geographic scope, and existing infrastructure.

Budget Category	Year 1 (Build)	Year 2+ (Run)	Notes
OT NDR Platform (licence + professional services)	High — majority of Year 1 capex	Medium (licence renewal)	Largest single technology cost; negotiate 3-year deal for better terms; include professional services for initial deployment and tuning
SIEM (OT tier — additive to existing)	Medium	Low-Medium	If extending existing enterprise SIEM, incremental data volume and OT content pack costs; standalone OT SIEM

Budget Category	Year 1 (Build)	Year 2+ (Run)	Notes
			requires full platform licence
Personnel (SOC analysts, lead)	High — dominant opex	High — dominant opex	Largest ongoing cost; OT security talent commands a 20–40% premium over pure IT security. Budget for 15% annual attrition and continuous training.
OT Threat Intelligence subscriptions	Low-Medium	Low-Medium	ISAC membership, specialist OT intel platforms, annual ICS threat landscape reports; non-negotiable for L3+ SOC maturity
Training and certifications (annual per analyst)	Medium	Medium	SANS ICS courses (ICS410, ICS515), ISA/IEC 62443 certifications, vendor-specific DCS/PLC training; plan USD 5,000–15,000 per analyst per year
Incident Response retainer (external firm)	Low	Low-Medium	OT-capable IR firm on retainer; ensure retainer agreement specifies OT-experienced responders, not generic IT IR team
Tabletop and Red/Purple Team exercises	Low	Low-Medium	Two tabletops + one red/purple team annually from L3 maturity; budget per exercise typically USD 20,000–80,000 depending on scope

11.3 Recommended Reading and Reference Standards

The following resources are essential reference material for OT SOC practitioners and leaders. All are publicly available or available through professional membership.

- IEC 62443 Series — Industrial Automation and Control System Security (definitive international standard series; parts 2-1, 2-4, 3-2, and 3-3 most relevant to SOC operations)
- NIST SP 800-82 Rev 3 — Guide to Operational Technology Security (comprehensive OT security guidance; free from NIST)

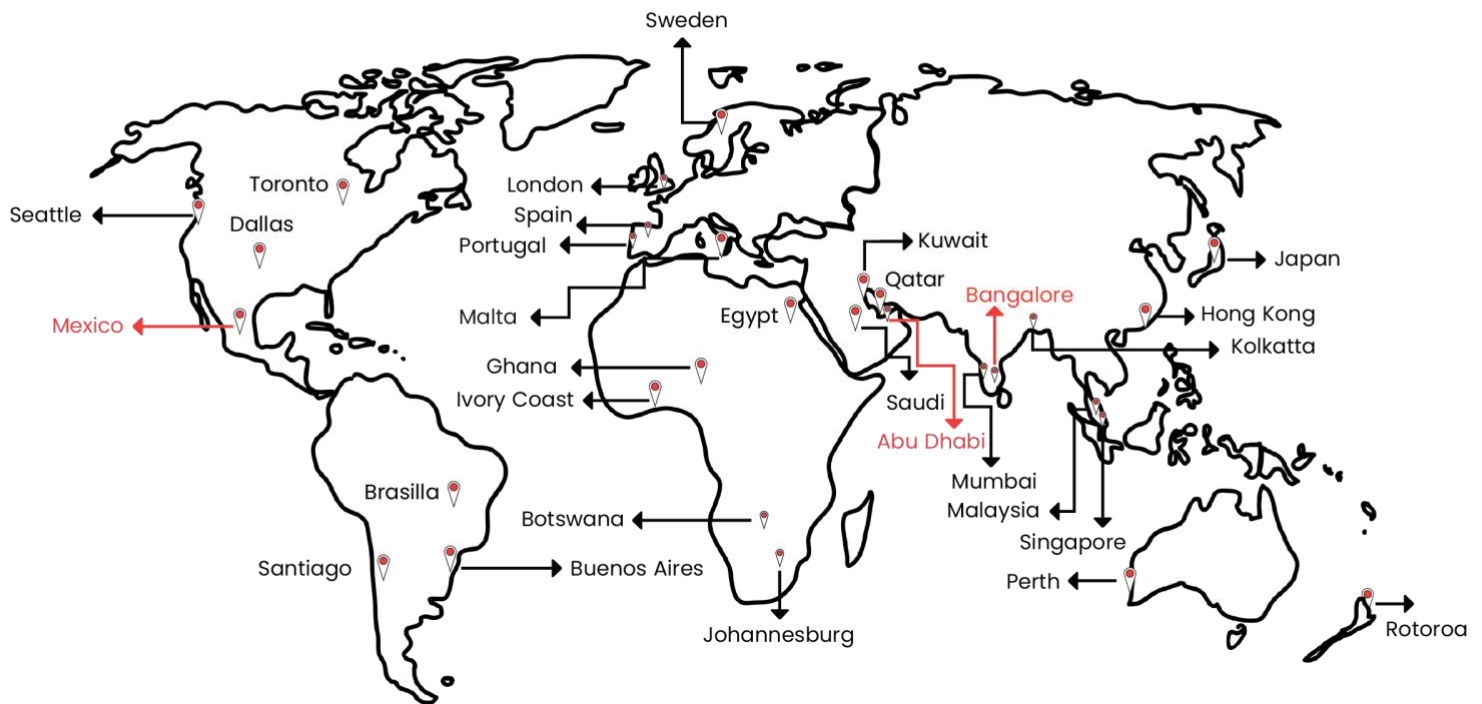
- CISA ICS-CERT Advisories and Year in Review reports — current OT vulnerability and threat landscape; subscribe at cisa.gov/ics
- [Shieldworkz OT Security Threat Landscape Report 2026](#) — industry-leading annual OT threat intelligence report
- NERC CIP Standards — mandatory for bulk electric system operations in North America; blueprint for OT control standards globally
- MITRE ATT&CK for ICS — adversary tactics, techniques, and procedures framework specifically for industrial environments; essential for use case development
- NIST Cybersecurity Framework 2.0 — overarching risk management framework with OT applicability guidance
- ISA/IEC 62443 Cybersecurity Certificate Programme — structured certification path for OT security practitioners
- E-ISAC / WaterISAC / Auto-ISAC — sector-specific threat intelligence sharing communities; membership provides access to sensitive threat intelligence not publicly available

11.4 Glossary of OT SOC Terms

Term	Definition
DCS	Distributed Control System — process control platform used in continuous process industries (refining, chemicals, power generation) to monitor and control complex industrial processes across distributed field instruments
EWS	Engineering Workstation — the computer used by control system engineers to develop, download, and modify logic for PLCs, RTUs, and DCS controllers. Highest-value target in OT network.
HMI	Human-Machine Interface — operator console providing visual representation of process state; target for both data exfiltration (process intelligence) and manipulation (alarm suppression)
ICS	Industrial Control System — umbrella term encompassing all OT control systems including SCADA, DCS, PLC-based systems, and safety systems
NDR	Network Detection and Response — technology that analyses network traffic to detect threats and support response; OT-specific NDR understands industrial protocols natively
OT	Operational Technology — hardware and software that monitors and controls physical processes, devices, and infrastructure; distinct from IT in its direct physical consequence domain
P&ID	Piping and Instrumentation Diagram — engineering drawing showing the process equipment, piping, instrumentation, and control elements of an OT system; essential reference document for OT SOC analysts
PLC	Programmable Logic Controller — industrial computer used to control discrete manufacturing processes and machinery; operates deterministic scan cycles and uses ladder logic or function block programming
Purdue Model	Reference model for ICS/SCADA architecture defining functional hierarchy levels L0 (field devices) through L5 (enterprise network); forms the basis for OT network segmentation design

Term	Definition
RTU	Remote Terminal Unit — field device that acquires data from sensors and actuators at remote locations and transmits to central SCADA systems; common in pipeline, power distribution, and water utility systems
SCADA	Supervisory Control and Data Acquisition — system for monitoring and controlling geographically distributed OT assets; aggregates data from RTUs and PLCs into central operator interface
SIS	Safety Instrumented System — independent protection layer that takes the process to a safe state when a hazardous condition is detected; governed by IEC 61511; highest-consequence OT attack target
SPAN	Switched Port Analyser — network switch feature that copies network traffic from one or more ports to a designated monitoring port; the primary collection mechanism for passive OT network monitoring
TTP	Tactics, Techniques, and Procedures — the behavioural fingerprint of a threat actor; MITRE ATT&CK for ICS catalogues OT-specific TTPs used by known threat groups

About Shieldworkz



ISOC and Honeypot Locations

Honeypot Locations



Security Operations Center



Shieldworkz is a global OT security company founded by top industry experts to protect critical infrastructure using proprietary technology and a leading consulting platform, we partner with businesses to secure assets, networks, and programs across industries. Our services are tailored to each client's cyber risks and backed by the world's largest OT and IoT threat intelligence facility and a global research team.

Secure Your Industrial Future

Talk to us



From OT security assessments covering NIS2, IEC 62443, NERC CIP and other regional requirements to an OT security platform, Shieldworkz covers all compliance and industrial cybersecurity enhancement needs. Talk to us to learn how you can enhance your security posture in 7 easy steps.

CONTACT US



- 📍 Fritz-Schäffer-Street 1,
4th floor
Bonn, 53113, Germany
- ☎ +49 (0) 228 / 929 39210
- ✉ europe@shieldworkz.com



- 📍 Tenth floor,
FAB BUSINESS CENTER
Abu Dhabi,
United Arab Emirates
- ☎ +971 56 660 5200
- ✉ middleeast@shieldworkz.com



- 📍 Gopalan Signature Tower,
No 6, 2nd Floor, Old Madras
Road, Benniganahalli
Bengaluru,
Karnataka 560093
- ☎ +91 9059620557
- ✉ apac@shieldworkz.com

